



ReadyPackets Go-Live Readiness Assessment

Feasibility review for a controlled public launch tomorrow evening

Prepared for ReadyPackets administrators

Assessment date: August 13, 2026 · Classification: Confidential operational assessment

Contents

1	Launch decision summary	1
2	Current readiness snapshot	1
3	Preconditions for a safe tomorrow-evening pilot	2
3.1	Non-negotiable launch blockers	2
3.2	Launch plan options	2
4	Tomorrow-evening runbook	2
4.1	T-24 to T-8 hours: evidence and change freeze	2
4.2	T-8 to T-1 hour: production readiness	3
4.3	Launch window: minimize blast radius	3
4.4	T+1 to T+24 hours: stabilization	3
5	Feature changes worth prioritizing after launch gates	3
6	Support, legal, and business operations	4
7	Suggested go/no-go checklist	4
8	Final recommendation	4
9	References	4

1 Launch decision summary

Recommendation: do not proceed with an unrestricted public launch tomorrow evening. A limited, invite-only pilot may be feasible only after the launch-blocking checklist in this report is completed and an accountable owner explicitly accepts remaining risks. The platform has a strong base: production HTTPS, Cloudflare-fronted architecture, nginx edge controls, loopback-only application/database exposure, MFA and session controls, security eventing, paid-order gates, protected backups, and a point-in-time clean dependency audit. These are meaningful strengths, not a substitute for an external assessment and operating-readiness proof.

The immediate launch blockers are: outbound webhook SSRF remediation and retest; a tested encrypted offsite backup destination; a controlled restore exercise; launch configuration smoke tests; and an independent authenticated assessment or formally accepted deferral. OWASP identifies SSRF, broken object/function authorization, authentication, resource consumption, misconfiguration, and unsafe third-party API consumption as key API risks. [2]

> A launch date should be a decision gate, not a calendar event. The decision should be based on evidence that security, recovery, support, payment, integration, and rollback controls work under realistic conditions.

2 Current readiness snapshot

Readiness area	Status	Decision rationale
Core hosting and transport	Green	The live origin is behind nginx and Cloudflare, the application and database bind locally, firewall inbound exposure is limited to 22/80/443, and the live portal serves HTTPS.

, [Application security baseline], [Amber-green], [Nonce CSP, CSRF, encryption, MFA, rate limits, audit data, IP controls, server-side gates, and protected helper designs are strong evidence of deliberate security work. An independent external assessment remains outstanding.]), [Webhook and external integrations], [Red], [Current server-side webhook delivery accepts arbitrary valid URLs. SSRF control and egress governance must be completed before external automation is broadly enabled.]), [Backup and recovery], [Amber], [Local backup status, verification, protected restore controls, and schedule are operational. The launch decision still requires an independent encrypted cloud target and a real restore rehearsal.]), [Payments, email, SSO], [Amber], [The platform has configuration and administrative tests, but each live integration must be exercised end-to-end with launch credentials and an operational owner.]), [Operational support], [Amber], [Security Centre and audit capabilities are improving. Support coverage, incident communications, monitoring escalation, and customer-service playbooks require finalization.]), [Product/user experience], [Amber], [Core customer workflow, file/audio intake, billing/invoices, orders, and administration exist. The most important remaining work is launch stabilization rather than broad new feature expansion.]))

3 Preconditions for a safe tomorrow-evening pilot

3.1 Non-negotiable launch blockers

Gate	Owner	Completion criterion	Evidence
G-1	Engineering/ security	Implement SSRF-safe outbound webhook controls or disable outgoing webhooks except for a fixed, approved staging receiver.	Automated negative tests and staging retest.

, [G-2], [Operations], [Configure at least one encrypted independent cloud backup target, run a backup, verify archive integrity, and document the restore owner.], [Successful synchronized archive and provider test record.]), [G-3], [Operations + engineering], [Execute a controlled restore rehearsal in a non-production environment or approved recovery target; record achieved RTO/RPO and gaps.], [Recovery report and sign-off.]), [G-4], [Business owner], [Complete end-to-end live-mode smoke tests: registration, MFA, password reset, email, Stripe checkout/webhook, invoice, customer upload/download, phase lock/unlock, workflow progress, support ticket, and admin recovery.], [Timestamped test checklist with expected/actual results.]), [G-5], [Security owner], [Obtain an external authenticated web/API assessment, or document an explicit risk acceptance and run a tightly limited invite-only beta.], [Assessment/retest report or signed risk acceptance.]), [G-6], [Cloudflare/DNS owner], [Confirm proxied DNS, Full (strict), active certificate hostname/expiry, TLS no-error experience, and origin protection plan.], [Screenshot/export and TLS validation.)))

3.2 Launch plan options

Approach	Tradeoffs	Recommendation
Unrestricted public launch tomorrow	Fastest business exposure but combines unknown attack paths, integration uncertainty, no restore rehearsal, and no external testing.	Not recommended.

, [Invite-only pilot after G-1 through G-6], [Restricts exposure to a small vetted cohort, enables support learning, and allows staged rollback while preserving a real customer path.], [Recommended path if gates are completed.]), [Internal/UAT launch tomorrow; public launch after remediation], [Lowest risk and ideal for completing Stripe/email/SSO/workflow/backup drills, but delays public availability.], [Recommended if any G-1 through G-6 gate is incomplete.)))

4 Tomorrow-evening runbook

4.1 T-24 to T-8 hours: evidence and change freeze

Stop non-essential feature development. Freeze the intended launch commit, publish its release notes, take and verify a protected backup, validate storage headroom, confirm alert ownership, and verify the on-call contact path. Run TypeScript, automated tests, security regression checks, and staged smoke tests against the same immutable build that will be deployed. OWASP recommends security activities throughout

requirements, design, implementation, verification, operations, and supply chain—not as a separate late phase. [3]

Confirm the configuration inventory: application URL, allowed origins, encryption-key backup location, email provider, Stripe live keys/webhook signing secret, Entra status, rate limits, IP allowlists, public pricing decision, backup retention, cloud target, Cloudflare DNS mode, and TLS certificate. Do not store this inventory with plaintext secrets.

4.2 T-8 to T-1 hour: production readiness

Place the service in a controlled maintenance or invite-only state while the final deployment occurs. Apply the immutable approved commit; run migrations; verify health/readiness; test browser headers; confirm active service/timer state; and run a synthetic customer/admin journey using test accounts. Ensure that a rollback snapshot exists before the migration and that the release owner can invoke it.

Verify Cloudflare Full (strict). It requires port 443 and an unexpired, hostname-matching origin certificate from a public CA or Cloudflare Origin CA. [6] If Cloudflare Origin CA is selected, remember that it is intended for Cloudflare-to-origin encryption; visitors may see certificate errors if proxying is paused or the record is unproxied. [5]

4.3 Launch window: minimize blast radius

Start with a small enrollment group. Monitor access failures, MFA enrollment, payment confirmations, email queue failures, webhook deliveries, upload errors, security events, database health, and backup job state. Freeze configuration changes except through the named release owner. Keep a clearly defined decision point for rollback if authentication, payment settlement, upload, data-integrity, or security-event thresholds are breached.

4.4 T+1 to T+24 hours: stabilization

Perform a structured review every two to four hours: conversion and checkout, support issues, failed emails, integration retries, security alerts, session anomalies, data errors, and resource utilization. Resolve or document all alerts. Do not add broad new features during this period. Convert recurring incidents into regression tests and runbooks.

5 Feature changes worth prioritizing after launch gates

The highest-value additions after the safety gates are not more surface area; they are operational completeness. Add a formal incident response center with notification routing, a staging environment with masked data, signed SBOMs and software-composition scanning in CI, webhook endpoint allowlists/egress policy, reportable RTO/RPO dashboards, certificate-expiry monitoring, formal consent/version analytics, and test-data tooling.

Product additions should follow measured customer demand: richer collaboration analytics, customer delivery experience metrics, configurable notification preferences, entitlement/renewal workflows, better document lifecycle/search, and accessibility validation in CI. Defer automation that can create external side effects until its authorization, idempotency, rate, retry, and audit controls are tested.

6 Support, legal, and business operations

Before inviting customers, publish customer support hours and an escalation contact, confirm refund and privacy policy links, verify legal terms acceptance, establish a breach/incident communication owner, and define refund/payment exception handling. Train administrators on account recovery, MFA replacement, customer deletion/purge controls, phase unlock, backup status, restore initiation, suspicious activity review, and webhook disablement.

A platform can be technically available yet operationally unready if there is no owner for a failed payment, a customer access problem, a missing document, a suspicious login, or a backup-recovery decision. Assign the owner and expected response time now.

7 Suggested go/no-go checklist

Question	Decision	Owner
Are all P0 remediation items complete, retested, and evidenced?	Go / No-go	Security owner

, [Is a verified independent encrypted backup current and is restore evidence available?], [Go / No-go], [Operations owner]], [Have live Stripe, email, SSO, registration, MFA, and webhook tests passed with the intended launch configuration?], [Go / No-go], [Integration owner]], [Is Cloudflare Full (strict) verified with a valid hostname-matching origin certificate?], [Go / No-go], [DNS/TLS owner]], [Are support, alert response, rollback, and communication owners staffed for the first 24 hours?], [Go / No-go], [Business owner]], [Has the release commit, migration plan, backup, and rollback snapshot been recorded?], [Go / No-go], [Release owner]])

8 Final recommendation

ReadyPackets can become launch-ready quickly because substantial security and operational foundations already exist. Tomorrow evening should be used for either an **internal/UAT validation** or a **small controlled pilot**, not an unrestricted public launch, unless every G-1 through G-6 gate is demonstrated and signed off. The decisive remediation is safe outbound webhook handling; the decisive operational proof is tested offsite recovery.

This recommendation is deliberately conservative. OWASP's secure-development guidance emphasizes verification, threat modeling, supply-chain controls, and operational security activities throughout the lifecycle. [3] A brief delay to prove those controls is lower cost than responding to a webhook-driven SSRF event, inaccessible customer data, or an unrecoverable production incident after public exposure.

9 References

- [1] OWASP, **OWASP Top 10:2025**. <https://owasp.org/Top10/2025/en/>
- [2] OWASP, **OWASP Top 10 API Security Risks – 2023**. <https://owasp.org/API-Security/editions/2023/en/0x11-t10/>
- [3] OWASP Developer Guide, **Secure development and integration**. <https://devguide.owasp.org/en/02-foundations/02-secure-development/>
- [4] OWASP, **Software Assurance Maturity Model (SAMM)**. <https://owasp.org/www-project-samm/>

- [5] Cloudflare, **Cloudflare Origin CA**. <https://developers.cloudflare.com/ssl/origin-configuration/origin-ca/>
- [6] Cloudflare, **Full (strict)**. <https://developers.cloudflare.com/ssl/origin-configuration/ssl-modes/full-strict/>
- [7] Cloudflare, **Create Origin CA Certificate API**. https://developers.cloudflare.com/api/resources/origin_ca_certificates/methods/create/